2026

ISO27

CNO IV: SEGURIDAD INFORMÁTICA

ALEJANDRO GARCIA MORALES

1. Alcance (Criterio PR02-11)

1.1 Información de la organización

INTERAFAS es el organismo operador de agua potable, alcantarillado y saneamiento que presta servicio a la población, integrando una capa de Tecnologías de la Información (portal ciudadano, APIs de facturación y contratación, portal periodístico de monitoreo reputacional) y una capa de Tecnología Operacional (telemetría, HMI y controladores de campo de la red de bombeo primaria).

Misión

Garantizar el suministro continuo, seguro y transparente de agua potable y saneamiento a la ciudadanía, sosteniendo la confianza pública mediante procesos digitales confiables y una operación industrial segura.

Visión

Ser un organismo operador de referencia en gobernanza digital e industrial, reconocido por la resiliencia de su infraestructura crítica y por la protección de la información de sus usuarios.

Objetivos estratégicos

- Asegurar la confidencialidad, integridad y disponibilidad de los activos de información IT y OT.
- Prevenir el salto lateral entre la red corporativa (IT) y la red de control industrial (OT).
- Cumplir con el marco legal de protección de datos personales aplicable a organismos públicos.
- Sostener la continuidad del servicio de bombeo ante incidentes de ciberseguridad.

Historia

INTERAFAS-LAB v1.0.0 representa el entorno contenerizado (Docker / WSL 2) desplegado para efectos de auditoría académica, replicando cinco componentes productivos: portal institucional, portal periodístico (Pulso Metropolitano), consola del Auditor, motor MariaDB y simulador operacional (HMI, gateway RTU-GW-07 y PLC de bombeo).

Organigrama (síntesis funcional)

- Alta Dirección — dirección general del organismo operador.
- Oficial de Seguridad de la Información (CISO) — gobierno del SGSI.
- Administración de Sistemas / Red — operación de infraestructura IT.
- Administración OT — operación de telemetría, HMI y controladores de campo.
- Desarrollo de Software — mantenimiento del portal y APIs ciudadanas.
- Auditoría Interna — verificación de cumplimiento.
- Atención Ciudadana y Contrataciones — procesos de cara al público.

1.2 Presentación del proyecto a la Alta Dirección

El presente proyecto de implementación de ISO/IEC 27001:2022 se presenta a la Alta Dirección de INTERAFAS como respuesta directa a los hallazgos del Informe Técnico de Seguridad Ofensiva, que evidenció 20 vulnerabilidades confirmadas o en investigación que comprometen desde la confidencialidad de expedientes ciudadanos hasta la integridad física de la planta de bombeo (estado CATASTROPHIC STATE).

- Dirección responsable: Dirección de Tecnologías de la Información y Operación, con reporte directo a la Dirección General.

- Área de ejecución: Oficina del Oficial de Seguridad de la Información (CISO), en coordinación con Sistemas, Desarrollo y Operación OT.
- Proceso donde se ejecutará: gobernanza del ciclo de vida del portal ciudadano, las APIs institucionales y el puente de operaciones IT→OT (gateway de operaciones).

Se solicita a la Alta Dirección la aprobación de la Política General de Seguridad de la Información (Sección 5.1) y de la hoja de ruta de remediación priorizada (0-48 horas, 1-2 semanas y 1-3 meses) ya establecida en el informe técnico de origen.

2. Referencias normativas (Criterio PR02-12)

De la familia de normas ISO/IEC 27000, se listan a continuación las 45 normas identificadas como de interés para INTERAFAS, indicando su alcance y su relevancia específica frente a los hallazgos de la auditoría de seguridad ofensiva.

Norma	Alcance	Relevancia para INTERAFAS-LAB
ISO/IEC 27000	Visión general y vocabulario del SGSI	Base terminológica de todo el documento
ISO/IEC 27001	Requisitos del SGSI	Norma certificable que estructura este proyecto PR02
ISO/IEC 27002	Controles de seguridad de la información	Fuente de los controles citados en la Sección 5 (Liderazgo)
ISO/IEC 27003	Guía de implementación del SGSI	Orienta la hoja de ruta de implementación
ISO/IEC 27004	Monitoreo, medición, análisis y evaluación	Sustenta la Sección 9 (Evaluación del desempeño)
ISO/IEC 27005	Gestión de riesgos de seguridad de la información	Metodología base de la matriz de riesgos (Sección 6)
ISO/IEC 27006	Requisitos para organismos de certificación/auditoría	Marco para auditorías externas futuras
ISO/IEC 27007	Directrices para auditoría de SGSI	Base de las listas de verificación (Sección 9)
ISO/IEC TS 27008	Guía para auditores sobre controles	Complementa la auditoría técnica de controles
ISO/IEC 27009	Aplicación sectorial de 27001	Aplicable al sector de servicios de agua (organismo operador)
ISO/IEC 27010	Gestión de seguridad para comunicaciones intersectoriales	Coordinación con medios (Pulso Metropolitano) e INTERAFAS
ISO/IEC 27011	Organizaciones de telecomunicaciones	Referencia para la infraestructura de red del portal
ISO/IEC 27013	Implementación integrada 27001 y 20000-1	Útil si se integra gestión de servicios de TI
ISO/IEC TR 27016	Economía organizacional de la seguridad	Justificación costo-beneficio ante Alta Dirección
ISO/IEC 27017	Controles para servicios en la nube	Aplicable si el portal migra a infraestructura cloud
ISO/IEC 27018	Protección de datos personales en nube pública	Relevante para expedientes ciudadanos (Activo A-03)
ISO/IEC 27019	Industria de servicios de energía/utilities	Análoga directa para OT de bombeo de agua (PLC, RTU-GW-07)
ISO/IEC TR 27021	Competencias de profesionales de SGSI	Define el perfil del Oficial de Seguridad (RACI, Sección 8)
ISO/IEC TS 27022	Guía de procesos del SGSI	Modelo de procesos para la operación (Sección 8)
ISO/IEC 27031	Preparación TIC para continuidad de negocio	Continuidad operativa de bombeo primario
ISO/IEC 27032	Directrices de ciberseguridad	Marco general de la auditoría ofensiva realizada
ISO/IEC 27033-1	Seguridad de redes — visión general	Segmentación IT/OT (Activo A-16, gateway)
ISO/IEC 27033-2	Diseño e implementación de seguridad de redes	Rediseño del gateway puente de operaciones
ISO/IEC 27033-3	Escenarios de referencia y amenazas de red	Modela la amenaza X-Forwarded-For (A-16)
ISO/IEC 27033-4	Aseguramiento de comunicaciones entre redes (gateways)	Aplicación directa al hallazgo BEYOND-THE-WEB
ISO/IEC 27033-5	Seguridad de redes privadas virtuales (VPN)	Base de la exigencia de VPN + MFA en el gateway OT
ISO/IEC 27033-6	Seguridad de acceso a redes IP inalámbricas	Referencia complementaria de red del laboratorio
ISO/IEC 27034-1	Seguridad de aplicaciones — visión general	Codificación segura (IDOR, XSS, SQLi, A-03/A-06/A-12)
ISO/IEC 27035-1	Principios de gestión de incidentes	Base de la minuta SGSI (Sección 7)
ISO/IEC 27035-2	Planificación y preparación de respuesta a incidentes	Procedimientos de escalamiento ante hallazgos críticos
ISO/IEC 27035-3	Operaciones de respuesta a incidentes TIC	Operación ante el estado CATASTROPHIC STATE

Norma	Alcance	Relevancia para INTERAFAS-LAB
ISO/IEC 27036-1	Relaciones con proveedores — visión general	Activo A-10, validación de vínculo proveedor-contrato
ISO/IEC 27036-2	Requisitos de seguridad en relaciones con proveedores	Gobernanza de contrataciones y licitaciones
ISO/IEC 27036-3	Seguridad de la cadena de suministro TIC	Cadena de suministro del firmware RTU-GW-07 (A-18)
ISO/IEC 27036-4	Seguridad en la nube dentro de relaciones con proveedores	Referencia si se subcontrata hosting
ISO/IEC 27037	Identificación y recolección de evidencia digital	Preservación de evidencias del pentest (logs, hashes)
ISO/IEC 27038	Especificación de redacción digital	Depuración de documentos públicos de transparencia
ISO/IEC 27039	Sistemas de detección/prevención de intrusiones	Monitoreo del gateway OT y del portal web
ISO/IEC 27040	Seguridad del almacenamiento	Protección de la base de datos MariaDB (A-12)
ISO/IEC 27041	Garantía de idoneidad de métodos de investigación	Rigor metodológico de la auditoría ofensiva realizada
ISO/IEC 27042	Análisis e interpretación de evidencia digital	Interpretación de hallazgos del informe técnico
ISO/IEC 27043	Principios de investigación de incidentes	Marco de las nueve fases metodológicas del pentest
ISO/IEC 27050-1	Descubrimiento electrónico — visión general	Gestión documental ante requerimientos legales
ISO/IEC 27070	Requisitos para raíces de confianza virtualizadas	Fortalecimiento de la firma digital de firmware (A-18)
ISO/IEC 29151	Código de práctica para protección de PII	Protección de datos personales de ciudadanos (A-03/A-08)

2.1 Marcos legales y regulatorios aplicables

Además de la familia ISO/IEC 27000, INTERAFAS debe observar los siguientes marcos legales y regulatorios que le competen como organismo operador de un servicio público esencial:

Marco legal / regulatorio	Aplicabilidad
Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados (LGPDPPSO)	INTERAFAS, como organismo operador público, está sujeto a esta ley por tratar datos personales de ciudadanos (expedientes, contratos, consumo).
Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)	Aplicable a proveedores y terceros privados que procesan datos por cuenta de INTERAFAS.
NOM-151-SCFI-2016	Conservación de mensajes de datos y digitalización de documentos; relevante para la evidencia digital del informe de auditoría.
Ley de Aguas Nacionales y su Reglamento	Marco regulatorio sectorial del organismo operador de agua; condiciona la continuidad del servicio de bombeo.
ISA/IEC 62443 (serie)	Marco de ciberseguridad industrial para sistemas de control (ICS/SCADA); aplicable a la zona OT (PLC, RTU-GW-07).
NIST SP 800-82 Rev. 3	Guía de seguridad de Tecnología Operacional (OT); referida explícitamente en el informe técnico.
NIST SP 800-193	Lineamientos de resiliencia de firmware de plataforma; base del dictamen de firma digital asimétrica (A-18).

3. Términos y condiciones (Criterio PR02-13)

A continuación se definen los términos de la norma ISO/IEC 27000:2018 (cláusula 3, Términos y definiciones) que la Alta Dirección requiere conocer para contextualizar la presentación del SGSI y comprender el Informe Técnico de Seguridad Ofensiva.

Término	Definición (ISO/IEC 27000)
Activo de información	Todo bien que tiene valor para la organización y requiere protección (ej. una base de datos, un PLC, un expediente).
Amenaza	Causa potencial de un incidente no deseado que puede dañar un sistema u organización.
Vulnerabilidad	Debilidad de un activo o control que puede ser explotada por una o más amenazas.
Riesgo de seguridad de la información	Efecto de la incertidumbre sobre los objetivos de seguridad, expresado como combinación de probabilidad e impacto.
Control	Medida que modifica el riesgo; puede ser administrativa, técnica, de gestión o legal.
Confidencialidad	Propiedad de que la información no esté disponible ni se divulgue a individuos, entidades o procesos no autorizados.
Integridad	Propiedad de exactitud y completitud de los activos de información.
Disponibilidad	Propiedad de ser accesible y utilizable a demanda por una entidad autorizada.
Sistema de Gestión de Seguridad de la Información (SGSI)	Conjunto de políticas, procedimientos, directrices y recursos para establecer, implementar, operar, monitorear y mejorar la seguridad de la información.
Incidente de seguridad de la información	Evento o serie de eventos que comprometen las operaciones del negocio y amenazan la seguridad de la información.
Declaración de Aplicabilidad (SoA)	Documento que describe los controles aplicables al SGSI de la organización y su justificación.
No conformidad	Incumplimiento de un requisito, identificado mediante auditoría o verificación de cumplimiento.

4. Contexto de la organización (Criterio PR02-14)

Se definen 20 activos de información del ecosistema INTERAFAS-LAB, 10 de naturaleza externa (expuestos o consumidos por el ciudadano / público) y 10 de naturaleza interna (infraestructura, sesión, base de datos y entorno OT), derivados directamente de los componentes auditados en el Informe Técnico de Seguridad Ofensiva.

4.1 Activos externos (10)

ID	Activo de información	Referencia técnica
A-01	Repositorio público de artefactos de despliegue	/assets/docs/public/revision/
A-02	Recursos JavaScript del cliente y metadatos de compilación	runtime-config.js, /assets/meta/build-manifest.php
A-03	Expedientes y datos contractuales de ciudadanos	/expediente.php, /api/account-context.php
A-04	Código fuente de páginas públicas (respaldos remanentes)	transparencia.php.bak
A-05	Servicio de exportación de catálogos públicos	/exportar.php?tipo=
A-06	Plataforma de reportes y seguimiento ciudadano	/reportes.php, /seguimiento-reporte.php
A-07	Catálogo de APIs ciudadanas	/api/account-context.php y endpoints relacionados
A-08	Historial de consumo y facturación por cuenta	/api/service-history.php
A-09	Módulo de pagos y liquidación de recibos	/pago.php
A-10	Módulo de validación de vínculos proveedor-contrato	/validar-vinculo-contractual.php

4.2 Activos internos (10)

ID	Activo de información	Referencia técnica
A-11	Mecanismo de control de acceso basado en roles (RBAC)	Cookies / parámetros de rol de sesión
A-12	Motor de base de datos transaccional MariaDB	interafas-lab-db-1
A-13	Repositorio de documentos y almacenamiento de archivos del servidor	/descargar-documento.php
A-14	Mecanismo de gestión del ciclo de vida de sesión	Cookie PHPSESSID / login.php
A-15	Mapa de topología de red y segmentación IT/OT	/infraestructura.php
A-16	Gateway puente de operaciones IT→OT	/operations/gateway.php
A-17	Consola HMI y servicio de telemetría de planta	HMI / telemetría de bombeo
A-18	Firmware y canal de actualización del gateway industrial	RTU-GW-07 (package.php / install.php)
A-19	Activos de control industrial encadenados	/operations/asset-context.php (6 activos IT→OT)
A-20	Parámetros de ingeniería y límites físicos del PLC Saint Louis	pressure_setpoint_bar

5. Liderazgo (Criterio PR02-15)

5.1 Política general de seguridad de la información

La Alta Dirección de INTERAFAS declara su compromiso con la protección de la confidencialidad, integridad y disponibilidad de los activos de información IT y OT del organismo operador. Esta política establece que: (1) toda decisión de autorización se validará exclusivamente en el servidor; (2) ningún control de seguridad descansará en la oscuridad de rutas ocultas ni en la confianza de atributos enviados por el cliente; (3) la frontera entre las redes de Tecnología de la Información (IT) y de Tecnología de la Operación (OT) se tratará como un límite de seguridad crítico sujeto a defensa en profundidad; (4) la autenticidad del firmware de los dispositivos de campo se garantizará mediante firma criptográfica asimétrica; y (5) todo parámetro físico de ingeniería estará sujeto a límites de seguridad inmutables e independientes del software de supervisión. Esta política es de cumplimiento obligatorio para todo el personal, proveedores y sistemas que interactúen con los activos descritos en la Sección 4, y será revisada anualmente o ante cambios significativos en el perfil de riesgo.

5.2 Políticas funcionales por activo de información

Cada una de las 20 políticas funcionales siguientes integra cuatro componentes: Estándar (control ISO/IEC 27002:2022 de referencia), Directriz (principio rector), Procedimiento (acción concreta derivada del dictamen de mitigación del informe técnico) y Línea base (umbral mínimo medible de cumplimiento).

A-01 — Repositorio público de artefactos de despliegue

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.37 Procedimientos documentados de operación / 8.9 Gestión de la configuración
Directriz	Ningún artefacto de compilación, empaquetado o despliegue (.zip, logs, manifest) debe residir en el document root público.
Procedimiento	Deshabilitar Options +Indexes en Apache; excluir *.zip, *.bak, *.old y deploy/ del pipeline de publicación (rsync --exclude).
Línea base	0 artefactos de despliegue accesibles por HTTP; barrido automatizado semanal.

A-02 — Recursos JavaScript del cliente y metadatos de compilación

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.28 Codificación segura / 8.26 Requisitos de seguridad de aplicaciones
Directriz	El código entregado al navegador no debe contener metadatos de arquitectura interna ni referencias a endpoints de diagnóstico.
Procedimiento	Minificar y limpiar comentarios del bundle de producción; retirar /assets/meta/build-manifest.php del entorno productivo.
Línea base	0 referencias a rutas de diagnóstico o build manifests en el bundle de producción.

A-03 — Expedientes y datos contractuales de ciudadanos

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.3 Restricción del acceso a la información / 5.15 Control de acceso
Directriz	Toda consulta de expediente debe validar que el identificador solicitado pertenece al titular de la sesión.
Procedimiento	Filtrar la consulta SQL simultáneamente por id de objeto y user_id de sesión; responder 403 ante discrepancia.
Línea base	100% de las consultas de expediente validadas contra el propietario de sesión.

A-04 — Código fuente de páginas públicas (respaldos remanentes)

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.9 Gestión de la configuración / 5.37 Procedimientos documentados
Directriz	Los archivos de respaldo y temporales no deben permanecer en el servidor de producción.
Procedimiento	Eliminar archivos .bak/.old/.tmp; bloquear extensiones de respaldo mediante FilesMatch en Apache.
Línea base	0 archivos de respaldo accesibles por HTTP; verificación en cada despliegue.

A-05 — Servicio de exportación de catálogos públicos

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.15 Registro / 8.9 Gestión de la configuración
Directriz	Los errores de aplicación nunca deben exponer trazas internas, rutas de sistema ni detalles de ejecución al usuario final.
Procedimiento	Incluir rama default en expresiones match; display_errors=Off y log_errors=On en producción.
Línea base	0 trazas de error (stack trace) visibles en respuestas HTTP de producción.

A-06 — Plataforma de reportes y seguimiento ciudadano

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.28 Codificación segura / 8.26 Requisitos de seguridad de aplicaciones
Directriz	Todo contenido generado por el usuario debe codificarse antes de representarse en HTML.
Procedimiento	Aplicar htmlspecialchars() a las salidas dinámicas e implementar cabecera Content-Security-Policy.
Línea base	100% de los campos de entrada de usuario sanitizados en la salida HTML.

A-07 — Catálogo de APIs ciudadanas

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.9 Inventario de activos de información / 8.26 Requisitos de seguridad de aplicaciones
Directriz	Todo endpoint de API debe estar documentado, inventariado y sujeto a los mismos controles de autorización que la interfaz principal.
Procedimiento	Mantener catálogo OpenAPI/Swagger actualizado; deshabilitar endpoints no consumidos por la versión vigente.
Línea base	100% de los endpoints activos documentados en el inventario de APIs.

A-08 — Historial de consumo y facturación por cuenta

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.3 Restricción del acceso a la información / 5.15 Control de acceso
Directriz	El acceso a datos de consumo y facturación debe estar restringido estrictamente a la cuenta vinculada al usuario autenticado.
Procedimiento	Validar la relación cuenta-usuario contra user_accounts antes de responder; 403 ante cuentas no vinculadas.
Línea base	100% de las solicitudes de historial validadas contra la cuenta propietaria de la sesión.

A-09 — Módulo de pagos y liquidación de recibos

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.26 Requisitos de seguridad de aplicaciones / 5.17 Información de autenticación
Directriz	El monto de cualquier transacción de pago debe determinarse exclusivamente en el servidor a partir del saldo real.
Procedimiento	Recalcular el saldo pendiente en base de datos (FOR UPDATE) y rechazar montos que no coincidan exactamente.
Línea base	0 liquidaciones aceptadas con monto distinto al saldo registrado en base de datos.

A-10 — Módulo de validación de vínculos proveedor-contrato

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.19 Seguridad de la información en relaciones con proveedores
Directriz	La validación de un vínculo contractual debe verificar la relación real proveedor-contrato, no solo la existencia aislada de cada entidad.
Procedimiento	Agregar verificación de llave foránea contrato-proveedor adjudicatario antes de emitir un estado de validación positivo.
Línea base	100% de las validaciones de vínculo contrastadas contra la relación contractual real.

A-11 — Mecanismo de control de acceso basado en roles (RBAC)

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.15 Control de acceso / 8.2 Derechos de acceso privilegiado
Directriz	El rol de un usuario debe determinarse y custodiarse exclusivamente en el servidor, nunca a partir de datos enviados por el cliente.
Procedimiento	Eliminar la lectura de rol desde cookies/parámetros; almacenar el rol únicamente en $_SESSION tras autenticación.
Línea base	0 decisiones de autorización basadas en atributos controlables por el cliente.

A-12 — Motor de base de datos transaccional MariaDB

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.28 Codificación segura / 8.29 Pruebas de seguridad en desarrollo
Directriz	Toda interacción con la base de datos debe realizarse mediante consultas preparadas con parámetros enlazados.
Procedimiento	Adoptar PDO con ATTR_EMULATE_PREPARES=false en la totalidad de los módulos que consultan MariaDB.
Línea base	100% de las consultas SQL parametrizadas; 0 concatenación directa de cadenas.

A-13 — Repositorio de documentos y almacenamiento de archivos del servidor

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.3 Restricción del acceso a la información / 8.28 Codificación segura
Directriz	Toda ruta de archivo solicitada por el usuario debe resolverse y validarse dentro de un directorio autorizado.
Procedimiento	Aplicar basename() y realpath() verificando que la ruta resuelta inicie dentro del directorio base permitido.
Línea base	0 lecturas de archivo fuera del directorio de almacenamiento autorizado.

A-14 — Mecanismo de gestión del ciclo de vida de sesión

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.17 Información de autenticación / 8.5 Autenticación segura
Directriz	El identificador de sesión debe regenerarse en cada cambio de nivel de privilegio, especialmente tras un inicio de sesión exitoso.
Procedimiento	Invocar session_regenerate_id(true) tras validar credenciales; configurar cookies con HttpOnly y SameSite=Lax.
Línea base	100% de los inicios de sesión con PHPSESSID regenerado; 0 reutilización de sesión pre-autenticación.

A-15 — Mapa de topología de red y segmentación IT/OT

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	5.9 Inventario de activos / 8.20 Seguridad de redes
Directriz	La topología de red, los rangos CIDR operacionales y las rutas puente IT/OT no deben divulgarse en páginas de acceso público.
Procedimiento	Retirar detalles de topología interna de /infraestructura.php; limitar dicha información a documentación interna clasificada.
Línea base	0 referencias a CIDR o rutas puente operacionales en contenido público.

A-16 — Gateway puente de operaciones IT→OT

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.20 Seguridad de redes / 8.22 Segregación de redes
Directriz	El acceso a la red operacional (OT) desde la red de aplicación web no debe confiar en cabeceras de origen falsificables por el cliente.
Procedimiento	Aislar /operations/gateway.php de la red pública, eliminar la confianza en X-Forwarded-For y exigir MFA sobre VPN.
Línea base	0 accesos a la red OT autorizados exclusivamente por cabecera X-Forwarded-For.

A-17 — Consola HMI y servicio de telemetría de planta

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.22 Segregación de redes / 5.15 Control de acceso
Directriz	La telemetría e interfaz HMI de planta debe exigir autenticación y autorización equivalentes a los activos críticos que representa.
Procedimiento	Igualar el control de sesión del HMI al del portal principal; auditar cada consulta de telemetría.
Línea base	100% de las consultas de telemetría HMI autenticadas y registradas.

A-18 — Firmware y canal de actualización del gateway industrial

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.29 Pruebas de seguridad en desarrollo / 8.8 Gestión de vulnerabilidades técnicas
Directriz	La autenticidad del firmware de dispositivos de campo debe garantizarse mediante firma criptográfica asimétrica, no solo integridad por hash.

Componente	Contenido
Procedimiento	Sustituir el digest SHA-256 verificable por el atacante por una firma digital asimétrica (NIST SP 800-193); revocar credenciales SHA-1 heredadas.
Línea base	100% de los paquetes de firmware verificados mediante firma digital antes de su instalación.

A-19 — Activos de control industrial encadenados

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.2 Derechos de acceso privilegiado / 5.18 Derechos de acceso
Directriz	El rol de mantenimiento no debe heredar acceso de encadenamiento completo (IT→OT) sin segmentación por activo.
Procedimiento	Aplicar el principio de mínimo privilegio por activo en asset-context.php; requerir aprobación por etapa para cada salto IT→OT.
Línea base	0 sesiones de mantenimiento con acceso simultáneo a los 6 activos de la cadena IT→OT.

A-20 — Parámetros de ingeniería y límites físicos del PLC Saint Louis

Componente	Contenido
Estándar (ISO/IEC 27002:2022)	8.9 Gestión de la configuración / 5.37 Procedimientos documentados de operación
Directriz	Todo parámetro físico de ingeniería cargado a un controlador debe validarse contra límites de seguridad inmutables antes de su aplicación.
Procedimiento	Implementar validación de rango en el PLC/gateway (pressure_setpoint_bar entre 2.5 y 5.5 bar) y enclavamientos físicos independientes (SIS).
Línea base	0 setpoints aplicados fuera del rango de ingeniería validado; SIS físico independiente operativo.

6. Planificación (Criterio PR02-16)

Se presenta la matriz de riesgos elaborada para las amenazas identificadas en cada una de las 20 políticas funcionales, siguiendo la metodología de ISO/IEC 27005. La probabilidad y el impacto se calibraron con base en la evidencia técnica reproducible documentada en el Informe Técnico de Seguridad Ofensiva (Sección 4 de dicho informe).

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel de riesgo	Tratamiento
A-01	Repositorio público de artefactos de despliegue	OPEN-DOOR — listado de directorios y ZIP de prelanzamiento expuesto (CWE-548)	Media	Alto	Medio-Alto	Mitigar
A-02	Recursos JavaScript del cliente y metadatos de compilación	LOOK-CLOSER — exposición de configuración y rutas de API en el cliente (CWE-200)	Media	Medio	Medio	Mitigar
A-03	Expedientes y datos contractuales de ciudadanos	NOT-YOURS — IDOR, acceso horizontal a expedientes ajenos (CWE-639)	Alta	Alto	Alto	Mitigar
A-04	Código fuente de páginas públicas (respaldos remanentes)	OLD-MEMORIES — divulgación de código fuente PHP (CWE-530)	Media	Alto	Medio-Alto	Mitigar
A-05	Servicio de exportación de catálogos públicos	TOO-MUCH-INFO — fuga de información por error no controlado (CWE-209)	Media	Medio	Medio	Mitigar
A-06	Plataforma de reportes y seguimiento ciudadano	STORED-WORDS — Cross-Site Scripting persistente (CWE-79)	Alta	Alto	Alto	Mitigar
A-07	Catálogo de APIs ciudadanas	HIDDEN-HISTORY — inventario de APIs no documentado (CWE-200 / API9:2023)	Media	Medio	Medio	Mitigar
A-08	Historial de consumo y facturación por cuenta	SECOND-ACCOUNT — BOLA, acceso a cuentas de terceros (CWE-639 / API1:2023)	Alta	Alto	Alto	Mitigar
A-09	Módulo de pagos y liquidación de recibos	PAYMENT-PATH — abuso de lógica de negocio en el flujo de pago (CWE-840)	Media	Alto	Medio-Alto	Mitigar
A-10	Módulo de validación de vínculos proveedor-contrato	TRUSTED-SUPPLIER — validación cruzada ausente proveedor-contrato (CWE-840)	Media	Medio	Medio	Mitigar
A-11	Mecanismo de control de acceso basado en roles (RBAC)	WRONG-ROLE — escalada vertical de privilegios (CWE-269 / A01:2021)	Alta	Crítico	Crítico	Mitigar
A-12	Motor de base de datos transaccional MariaDB	SILENT-ANSWER — SQL Injection ciega basada en inferencia booleana (CWE-89)	Alta	Crítico	Crítico	Mitigar
A-13	Repositorio de documentos y almacenamiento de archivos del servidor	TOO-DEEP — Path Traversal, lectura arbitraria de archivos (CWE-22)	Media	Alto	Medio-Alto	Mitigar
A-14	Mecanismo de gestión del ciclo de vida de sesión	WHO-ARE-YOU — fijación de sesión (CWE-384)	Alta	Alto	Alto	Mitigar
A-15	Mapa de topología de red y segmentación IT/OT	BEHIND-THE-DESK — exposición de topología interna y CIDR operacional (CWE-200)	Media	Medio	Medio	Mitigar
A-16	Gateway puente de operaciones IT→OT	BEYOND-THE-WEB — bypass de control de acceso vía X-Forwarded-For (CWE-290/348)	Alta	Crítico	Crítico	Mitigar
A-17	Consola HMI y servicio de telemetría de planta	EYES-ON-THE-PLANT — acceso no autorizado a telemetría operativa (CWE-306/284)	Alta	Alto	Alto	Mitigar
A-18	Firmware y canal de actualización del gateway industrial	TRUST-THE-PACKAGE — hash débil SHA-1 y firmware sin firma digital (CWE-328/345/347)	Alta	Crítico	Crítico	Mitigar

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel de riesgo	Tratamiento
A-19	Activos de control industrial encadenados	CHAIN-REACTION — exceso de privilegios del rol maintenance (CWE-250/269)	Alta	Crítico	Crítico	Mitigar
A-20	Parámetros de ingeniería y límites físicos del PLC Saint Louis	NOW-YOU-CONTROL — alteración de setpoint sin validación de límites (MITRE T0836 / CWE-20)	Alta	Crítico	Crítico	Evitar (límite físico inmutable)

6.1 Administración del riesgo

INTERAFAS administrará el riesgo mediante las cuatro estrategias reconocidas por ISO/IEC 27005:

- Mitigar: aplicar el control técnico descrito en la política funcional correspondiente (estrategia dominante, 19 de 20 riesgos) hasta llevar el riesgo residual a un nivel aceptable.
- Evitar: eliminar la condición que origina el riesgo cuando el impacto potencial es catastrófico e irreversible; aplica al riesgo A-20 (alteración de pressure_setpoint_bar), donde se impone un límite físico inmutable (Sistema Instrumentado de Seguridad) independiente del software, de modo que ningún valor de software pueda provocar sobrepresión real.
- Transferir: contratar cobertura de ciberseguro para los riesgos de fraude financiero (A-09, PAYMENT-PATH) y de responsabilidad civil por filtración de datos personales (A-03, A-08), complementando — nunca sustituyendo — el control técnico.
- Aceptar: reservado para riesgos residuales de nivel Medio una vez aplicados los controles de mitigación, previa autorización documentada de la Alta Dirección y revisión semestral.

Todo riesgo clasificado como Crítico (A-11, A-12, A-16, A-18, A-19, A-20) se escala de forma inmediata al Comité SGSI y se incorpora a la Prioridad Inmediata (0-48 horas) de la hoja de ruta de remediación.

7. Soporte (Criterio PR02-17)

7.1 Minuta de socialización del SGSI

Campo	Detalle
Fecha	16 de octubre de 2026
Lugar	Sala de juntas — Dirección de Tecnologías de la Información, INTERAFAS
Convocados	Alta Dirección, Oficial de Seguridad de la Información (CISO), Administración de Sistemas, Administración OT, Desarrollo de Software, Auditoría Interna, Atención Ciudadana y Contrataciones
Objetivo	Dar a conocer el Sistema de Gestión de Seguridad de la Información (SGSI) y los hallazgos críticos del Informe Técnico de Seguridad Ofensiva
Temas tratados	(1) Resumen ejecutivo de los 20 hallazgos; (2) cadena de ataque IT→OT y su culminación en CATASTROPHIC STATE; (3) política general de seguridad; (4) hoja de ruta de remediación priorizada
Acuerdos	A1) Aprobar la Política General de Seguridad de la Información. A2) Aislar de inmediato /operations/gateway.php de la red pública. A3) Asignar presupuesto para firma digital de firmware (NIST SP 800-193). A4) Programar capacitación obligatoria en codificación segura para el equipo de Desarrollo. A5) Instalar enclavamientos físicos independientes (SIS) en la zona de bombeo primario.
Áreas de oportunidad detectadas	Ausencia de un inventario formal de APIs; falta de un canal de reporte de vulnerabilidades; carencia de segmentación de red IT/OT; dependencia de controles del lado del cliente en múltiples módulos.
Próxima revisión	Sesión de seguimiento en 30 días para validar el avance de los Acuerdos A1-A5

7.2 Soporte documental de prevención

A partir de las amenazas de mayor severidad identificadas en la matriz de riesgos (Sección 6), se desarrolla el siguiente soporte documental dirigido a los distintos públicos internos y ciudadanos.

Flyer de concienciación ciudadana

- Título: "Tu información, protegida: así cuidamos tu expediente en INTERAFAS"
- Mensaje clave: cómo reportar comportamientos sospechosos en el portal (p. ej. recibir datos de otro usuario) a través del canal oficial de Atención Ciudadana.
- Contenido: qué información resguarda INTERAFAS, derechos ARCO, canal de contacto para incidentes de privacidad.

Presentación ejecutiva para Alta Dirección y mandos medios

- Título: "De un ZIP olvidado al CATASTROPHIC STATE: la cadena de ataque IT→OT en INTERAFAS-LAB"
- Estructura: contexto, resumen de los 20 hallazgos, diagrama de la cadena de ataque (Sección 5 del informe técnico), hoja de ruta de remediación, solicitud de aprobación presupuestal.

Curso interno de codificación segura (Desarrollo de Software)

- Módulo 1: Control de acceso a nivel de objeto (IDOR/BOLA) — casos A-03, A-08.
- Módulo 2: Inyección SQL y consultas preparadas — caso A-12.
- Módulo 3: Codificación de salida y prevención de XSS — caso A-06.
- Módulo 4: Gestión segura de sesiones — caso A-14.
- Módulo 5: Validación de rutas de archivo y path traversal — caso A-13.
- Evaluación final: laboratorio práctico de remediación sobre una réplica controlada de INTERAFAS-LAB.

Video de sensibilización para Operación OT

- Título: "4.2 a 99.9 bar: cómo un parámetro de software casi provoca un desastre físico"
- Guion: reconstrucción narrada de la Fase 5 del informe (abuso del rol maintenance, alteración de pressure_setpoint_bar, estado CATASTROPHIC STATE) y la importancia de los enclavamientos físicos independientes.
- Público objetivo: Administración OT y personal de mantenimiento de planta.

8. Operación (Criterio PR02-18)

Matriz RACI (Responsable, Aprobador, Consultado, Informado) para las principales actividades operativas del SGSI de INTERAFAS.

Actividad	Responsable (R)	Aprobador (A)	Consultado (C)	Informado (I)
Definición y aprobación de la política general de seguridad	Alta Dirección	Oficial de Seguridad (CISO)	Comité SGSI	Todo el personal
Gestión del inventario de activos de información	Oficial de Seguridad	Administrador de Sistemas	Alta Dirección	Desarrolladores
Evaluación y tratamiento de riesgos (matriz de riesgos)	Oficial de Seguridad	Auditor Interno	Alta Dirección	Administrador de Sistemas
Corrección de vulnerabilidades en código (IDOR, XSS, SQLi)	Desarrolladores	Líder técnico	Oficial de Seguridad	Auditor Interno
Segmentación y control de acceso a la red OT	Administrador de Sistemas / Red	Oficial de Seguridad	Alta Dirección	Operadores de planta
Gestión de incidentes de seguridad	Oficial de Seguridad	Equipo de respuesta a incidentes	Alta Dirección	Todo el personal
Gestión de parches y actualizaciones de firmware OT	Administrador OT	Oficial de Seguridad	Proveedor del dispositivo	Operadores de planta
Capacitación y concienciación en seguridad	Oficial de Seguridad	Recursos Humanos	Alta Dirección	Todo el personal
Gestión de la relación con proveedores (contrataciones)	Área de Contrataciones	Oficial de Seguridad	Alta Dirección	Proveedores
Auditoría interna y verificación de cumplimiento (checklist)	Auditor Interno	Oficial de Seguridad	Alta Dirección	Administrador de Sistemas

9. Evaluación del desempeño (Criterio PR02-19)

Se implementa la siguiente lista de verificación para determinar el cumplimiento y funcionamiento de cada política funcional, con base en el estado observado durante la auditoría de seguridad ofensiva (línea base "antes de la remediación"). Este checklist constituye la entrada directa de la Sección 10 (Mejora).

ID	Criterio evaluado	Estado	Evidencia
A-01	Repositorio público de artefactos de despliegue	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-02	Recursos JavaScript del cliente y metadatos de compilación	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-03	Expedientes y datos contractuales de ciudadanos	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-04	Código fuente de páginas públicas (respaldos remanentes)	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-05	Servicio de exportación de catálogos públicos	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-06	Plataforma de reportes y seguimiento ciudadano	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-07	Catálogo de APIs ciudadanas	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-08	Historial de consumo y facturación por cuenta	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-09	Módulo de pagos y liquidación de recibos	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-10	Módulo de validación de vínculos proveedor-contrato	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-11	Mecanismo de control de acceso basado en roles (RBAC)	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-12	Motor de base de datos transaccional MariaDB	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-13	Repositorio de documentos y almacenamiento de archivos del servidor	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-14	Mecanismo de gestión del ciclo de vida de sesión	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-15	Mapa de topología de red y segmentación IT/OT	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.

ID	Criterio evaluado	Estado	Evidencia
A-16	Gateway puente de operaciones IT→OT	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-17	Consola HMI y servicio de telemetría de planta	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-18	Firmware y canal de actualización del gateway industrial	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-19	Activos de control industrial encadenados	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.
A-20	Parámetros de ingeniería y límites físicos del PLC Saint Louis	No cumple	Ver Sección 4 del Informe Técnico de Seguridad Ofensiva — hallazgo confirmado mediante PoC reproducible.

Resultado global: 20 de 20 criterios (100%) se encontraron en estado "No cumple" al momento de la auditoría, confirmando que el SGSI se encuentra en fase de diseño/implementación inicial y que ninguna de las políticas funcionales operaba de forma efectiva antes de este proyecto.

10. Mejora (Criterio PR02-20)

10.1 Rediseño del soporte de prevención a partir del checklist de auditoría

Dado que el checklist de la Sección 9 confirmó una tasa de incumplimiento del 100% al momento de la auditoría, el soporte documental de prevención (Sección 7.2) se rediseña incorporando verificación activa en lugar de únicamente concienciación pasiva:

- El flyer ciudadano incorpora un código QR que enlaza a un formulario de reporte de anomalías de privacidad, con acuse de recibo automático y SLA de respuesta de 48 horas.
- La presentación ejecutiva se convierte en un tablero de seguimiento trimestral (dashboard) que contrasta el checklist "antes" (Sección 9) contra el checklist "después" de cada ciclo de remediación, presentado a la Alta Dirección.
- El curso de codificación segura se complementa con una puerta de calidad obligatoria (gate) en el pipeline de integración continua: ningún cambio se publica si reintroduce un patrón ya catalogado como vulnerabilidad confirmada (IDOR, SQLi, XSS, path traversal).
- El video de sensibilización OT se refuerza con un simulacro trimestral de sobrepresión controlada para validar en campo que el enclavamiento físico independiente (SIS) detiene la condición antes de alcanzar el estado CATASTROPHIC STATE.

10.2 Mejora de la política funcional que no logró el objetivo

De los 20 criterios evaluados, el de mayor severidad y con el impacto más catastrófico es A-20 — Parámetros de ingeniería y límites físicos del PLC Saint Louis (NOW-YOU-CONTROL), cuya política funcional original (Sección 5.2) exigía validación de rango en software pero no logró el objetivo: el controlador aceptó y aplicó un valor de pressure_setpoint_bar muy por fuera de su línea base de ingeniería (4.2 bar) sin ninguna verificación, desencadenando sobrepresión, saturación de alarmas y caída de disponibilidad.

Política funcional mejorada A-20 (versión 2):

Componente	Versión original (no logró el objetivo)	Versión mejorada
Estándar	8.9 Gestión de la configuración (control únicamente a nivel de software)	8.9 Gestión de la configuración + 8.22 Segregación de redes + control físico independiente conforme a NIST SP 800-82 Rev. 3
Directriz	Todo parámetro cargado al controlador debe validarse contra límites de ingeniería	Ningún parámetro de software, por sí solo, debe poder provocar una condición física insegura; el límite debe existir también fuera del alcance del software
Procedimiento	Validación de rango (2.5-5.5 bar) implementada únicamente en el gateway/HMI	Validación de rango en el gateway (defensa en profundidad, capa 1) + válvula de alivio de sobrepresión mecánica y relé de paro de emergencia independientes de la red de telemetría (Sistema Instrumentado de Seguridad, capa 2), conforme al dictamen del informe técnico (Sección 4.20.5)
Línea base	0 setpoints fuera de rango aceptados por el software	0 setpoints fuera de rango aceptados por el software Y verificación física trimestral de que el SIS actúa de forma autónoma ante una señal de sobrepresión, incluso con el software comprometido

Esta mejora materializa la conclusión central del Informe Técnico de Seguridad Ofensiva: la diferencia entre integridad y autenticidad en entornos OT exige controles que no dependan exclusivamente del software, sino de límites físicos inmutables, cerrando así el ciclo de mejora continua (Plan-Do-Check-Act) del SGSI de INTERAFAS.

Referencias

- OWASP Foundation. (2021). OWASP Web Security Testing Guide (WSTG) v4.2.
- OWASP Foundation. (2023). OWASP API Security Top 10 2023.
- MITRE Corporation. (2024). ATT&CK for Industrial Control Systems (ICS).
- MITRE Corporation. (2024). Common Weakness Enumeration (CWE).
- NIST. (2023). SP 800-82 Rev. 3: Guide to Operational Technology (OT) Security.
- NIST. (2018). SP 800-193: Platform Firmware Resiliency Guidelines.
- ISO/IEC. (2022). ISO/IEC 27001 — Information security management systems — Requirements.
- ISO/IEC. (2022). ISO/IEC 27002 — Information security controls.
- ISO/IEC. (2018). ISO/IEC 27000 — Overview and vocabulary.
- ISO/IEC. (2022). ISO/IEC 27005 — Information security risk management.
- 02__ApellidosNombre_InformeSeguridadOfensiva_-_INTERAFAS-LAB_v2.docx (documento fuente de los hallazgos técnicos).